

CODING TEMPLE
GIANNINA BARIANI

COMPREHENSIVE SECURITY AUDIT

BOOKSTER ONLINE RETAIL



1. Company Overview

Company Name: Bookster

Industry: Online Retail – Books

Size: 250 employees

Headquarters: Miami, FL (fully remote operations)

Website: bookster.com

Description:

Bookster is an innovative online bookstore offering both physical and digital books through a web platform and a mobile app for iOS and Android. Customers can browse, purchase, and read books, as well as post reviews and ratings.

Data Handled:

- **Customer Data:** Names, emails, shipping addresses, payment information, purchase history.
- **Employee Data:** HR records, payroll data, PII.
- **Business Data:** Book inventory, publisher agreements, API integrations with payment processors.

Bookster's infrastructure is hosted on a **cloud-based environment (AWS)** with integrations to a **CRM (Salesforce)** and **payment gateway (Stripe)**.

2. Network and System Security

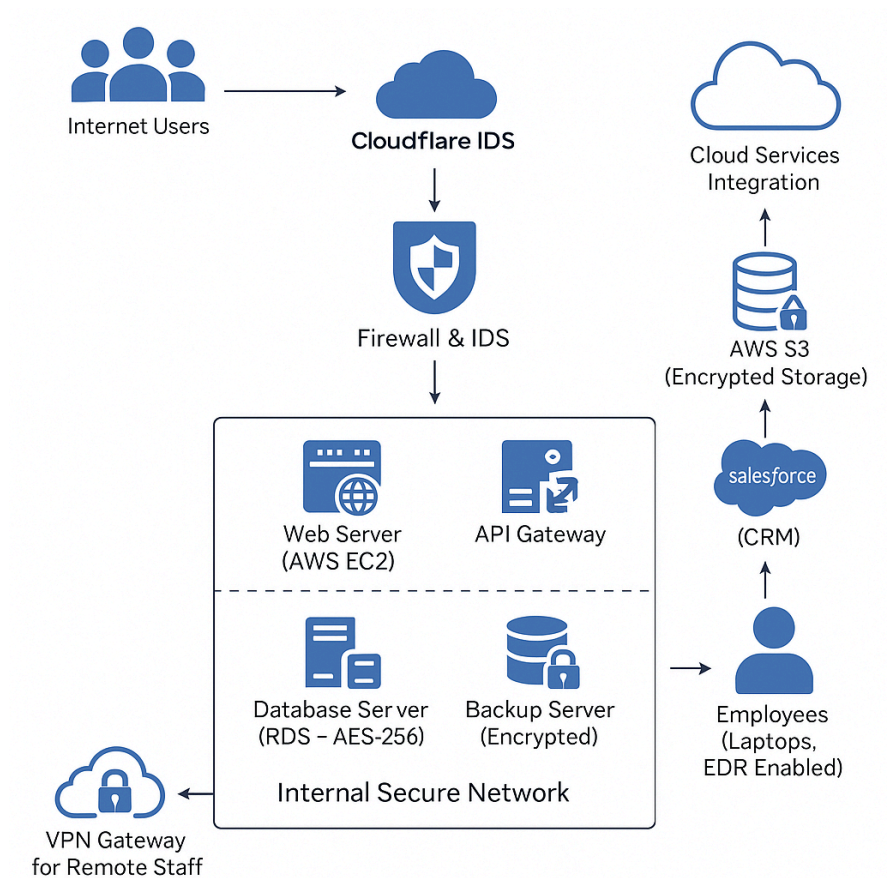
Network Design

Bookster uses a hybrid cloud model combining AWS services and a secure on-premise gateway for internal employee access.

Key Components:

- **Perimeter Firewall:** Controls inbound/outbound traffic between the internet and internal networks (e.g., Cisco ASA or FortiGate).
- **IDS/IPS:** Monitors network traffic for anomalies using tools like **Snort** or **Suricata**.
- **VPN Gateway:** Provides secure remote access for employees using **IPSec VPN**.
- **DMZ (Demilitarized Zone):** Hosts public-facing services like the website and APIs separately from internal databases.
- **Endpoint Security:** All employee devices are protected with **EDR (CrowdStrike Falcon)**.
- **Email Security:** Uses **Microsoft Defender for Office 365** with phishing filters and attachment scanning.

Network Diagram (Conceptual)



Rationale:

This layered security approach (defense-in-depth) ensures that even if one control fails (e.g., web app compromised), other layers (firewall, IDS, VPN authentication) maintain protection.

3. Application and Web Security

Bookster's web and mobile platforms are analyzed according to the **OWASP Top 10 (2021)**.

Vulnerability	Risk Description	Remediation
A01: Broken Access Control	Unauthorized data access	Implement role-based access and session tokens
A02: Cryptographic Failures	Weak SSL/TLS settings	Enforce TLS 1.3, HSTS headers, AES-256 encryption
A03: Injection	SQL/NoSQL injection in search fields	Use parameterized queries and ORM
A04: Insecure Design	Missing input validation	Validate all client-side and server-side inputs
A05: Security Misconfiguration	Default admin pages exposed	Remove default credentials, restrict admin panel
A06: Vulnerable Components	Outdated dependencies	Use automated vulnerability scanning (Dependabot)
A07: Identification and Authentication Failures	Weak password policy	MFA and strong password requirements
A08: Software and Data Integrity Failures	Tampering in app updates	Use digital signatures for app binaries
A09: Security Logging and Monitoring	No incident visibility	Integrate with SIEM (Splunk / Sentinel)

A10: SSRF

Exploiting backend
services

Whitelist allowed URLs and
validate all requests

4. Cryptography

Data Encryption

- **In Transit:** TLS 1.3 with HSTS for all HTTPS connections.
- **At Rest:** AES-256 for databases and AWS S3 storage buckets.
- **Email Encryption:** S/MIME for sensitive internal communication.

Key Management

- AWS KMS used for automated key rotation every 90 days.
 - Access to encryption keys limited to system administrators only.
 - Encrypted backups stored on separate cloud regions.
-

5. Incident Response and Risk Management

Incident Response Plan (IRP)

Phases:

1. **Preparation:** Training employees, maintaining backups, updating playbooks.
2. **Identification:** Use SIEM alerts to detect anomalies or breaches.
3. **Containment:** Isolate affected servers or users.
4. **Eradication:** Remove malware, patch vulnerabilities.
5. **Recovery:** Restore from backups, test systems.
6. **Lessons Learned:** Document incident report and improve defenses.

Team Roles:

- **Incident Manager:** Leads response efforts.
- **Forensic Analyst:** Collects and preserves digital evidence.
- **Communications Officer:** Manages internal and external updates.
- **Legal & Compliance:** Coordinates breach notifications.

Communication Plan:

- Use encrypted channels (Signal, Teams).

- Notify leadership and legal team within 1 hour of detection.
- Public disclosure (if required) within 72 hours per GDPR/CCPA.

Risk Assessment

Asset	Threat	Likelihood	Impact	Risk Level	Mitigation
Customer DB	SQL Injection	High	High	Critical	Input validation, WAF
Web Server	DDoS Attack	Medium	High	High	Cloudflare CDN, rate limiting
Employee Accounts	Phishing	High	Medium	High	MFA, phishing simulation
Cloud Storage	Misconfiguration	Medium	High	High	Regular audits, IAM policies
Mobile App	Data leakage	Low	Medium	Medium	App encryption, secure SDKs

6. Cloud and Mobile Security

Cloud Security (AWS)

- **IAM Policies:** Principle of least privilege.
- **CloudTrail Logs:** Monitored via AWS GuardDuty.
- **Data Backups:** Encrypted and replicated across regions.
- **WAF & Shield:** Protect against DDoS and injection attacks.

Mobile Security

- Encrypted local storage (Keychain/Keystore).
 - App attestation to prevent tampering.
 - In-app authentication via OAuth 2.0 and refresh tokens.
 - Disable screenshots for sensitive screens (e.g., payment).
-

7. Security Policies and Standards

Standard Alignment

Bookster's Information Security Management System (ISMS) follows **ISO/IEC 27001**.

Policy Highlights

- **Acceptable Use Policy:** Defines proper use of company assets.
- **Access Control Policy:** Role-based access and MFA enforcement.
- **Data Classification Policy:** Confidential, Internal, Public.
- **Password Policy:** 12+ characters, includes complexity rules.
- **BYOD Policy:** Devices must be encrypted and enrolled in MDM (Intune).

Auditing Procedures

- Quarterly internal audits and annual external ISO audits.
 - Monthly vulnerability scans and patch reviews.
 - Audit logs stored for 12 months in secure storage.
-

8. Conclusion

Bookster's layered security model provides robust protection against both external and internal threats. By implementing advanced encryption, zero-trust access, and continuous monitoring, Bookster ensures confidentiality, integrity, and availability (CIA Triad) across all assets.

Ongoing training and audits will maintain compliance and readiness against evolving threats.